Сканер утечек в коде

NuclearSecretSeeker

Команда **2b1o:**
Лопатин Кирилл
Фадеев Олег
Григорян Тигран

Проблема

Секреты часто случайно попадают в исходный код и конфигурационные файлы: API-ключи, токены доступа, пароли и приватные ключи.

Человеческий фактор

Разработчики часто добавляют секреты в код для локального тестирования и случайно коммитят их в репозиторий.

Масштаб проектов

Ручная проверка кода становится практически невозможной.

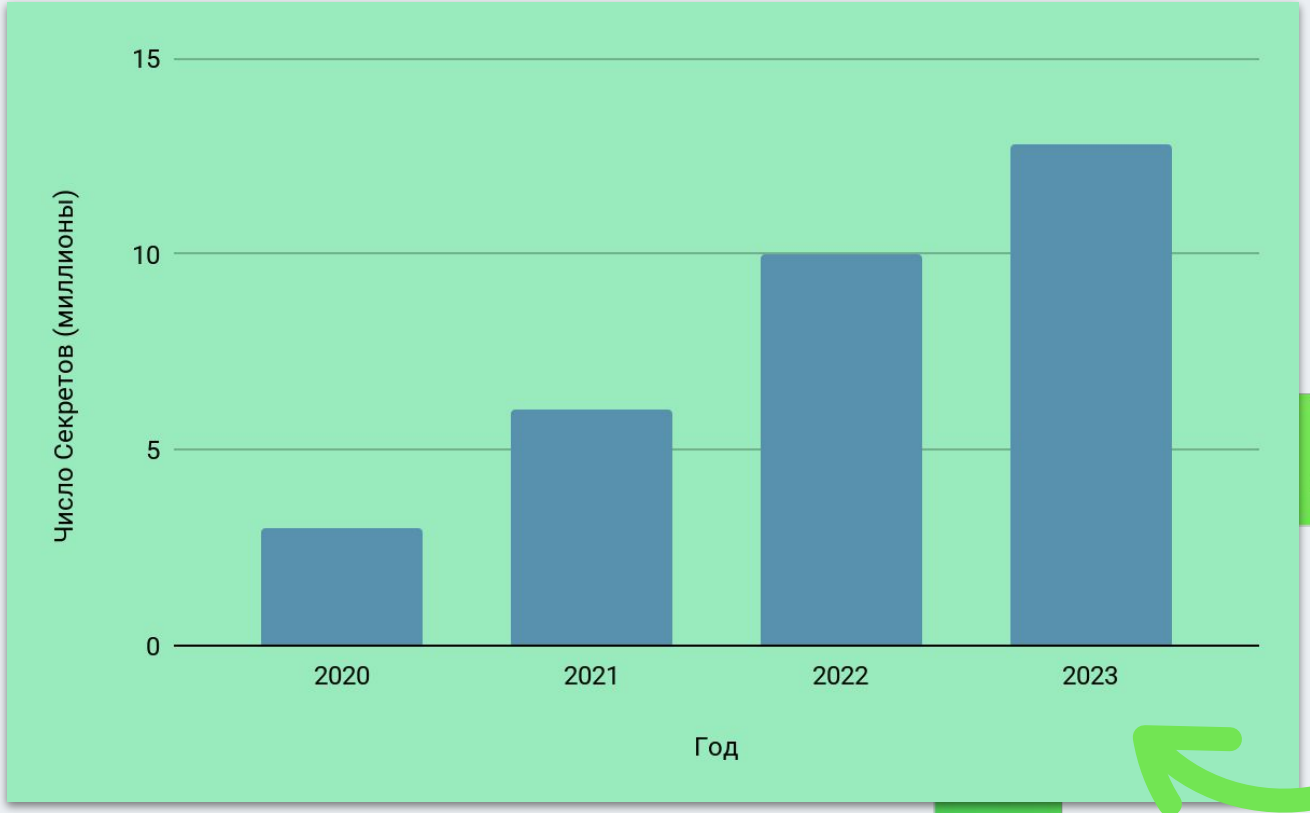
Опасность публичных репозиториев

Попавшие в Git секреты могут быть быстро обнаружены злоумышленниками.

Недостаток автоматизации

Существующие инструменты требуют отдельной настройки и запуска, поэтому часто игнорируются или отключаются разработчиками.

Статистика **Github**: утечка секретов в публичных репозиториях



Запуск Cursor

Существующие решения ☹

GitLeaks

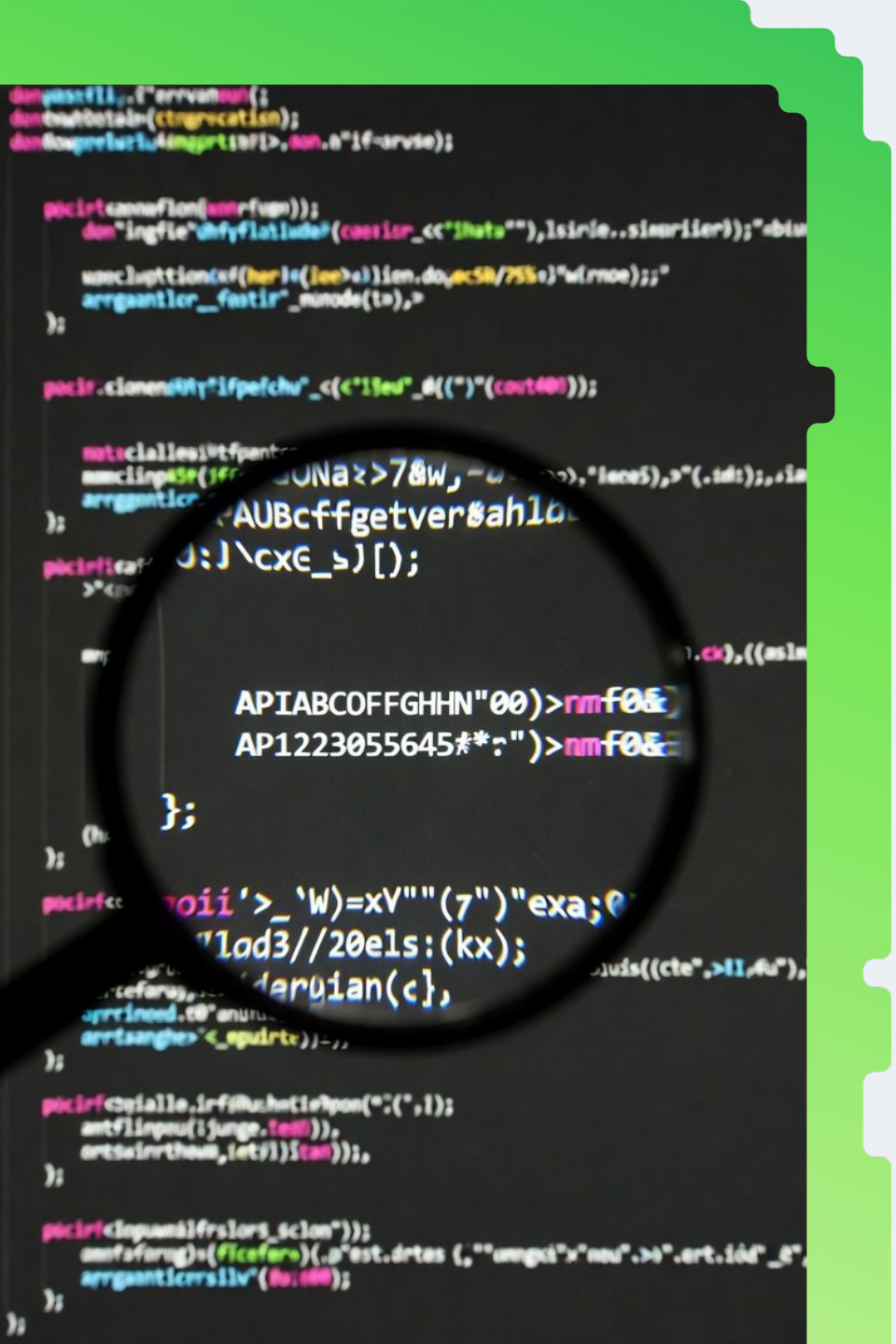
Требует отдельной настройки и запуска. Часто генерирует ложные срабатывания и неудобен для обычных разработчиков.

TruffleHog

Медленный при сканировании больших репозиториев и требует сложной конфигурации для практического использования.

detect-secrets

Эффективен только при правильной настройке baseline и правил, что усложняет внедрение в команды.



NuclearSecretSeeker ☺

- Устанавливается одной командой
- Не мешает разработчику
- Даёт интерактивный интерфейс
- Обнаруживает секрет до попадания в git

Plug & Play подход

Доступно через **apt**

Подключение к локальному репозиторию:

nuclearss install [path]

Создается конфиг .nuclearss

Добавляются githook’и

Автоматически проверяет commit, push

Разработчику не нужно:

- менять workflow
- запускать команды

Как работает?

git commit (push)

git hook

запускает nuclearss

Seeker анализирует сурс

Используя типовые паттерны *regex*

утечек секрета нет!

Успешный коммит

секрет найден

Запуск TUI

Интерактивный TUI показывает проблемы, позволяя разрешить их сразу в терминале

Секрет **не попадает** в историю git **вообще**.

Архитектура

nuclearss-seeker

Движок поиска утечек

Учитывает .gitignore, **.nuclearss** флаги **-x**. результат в **JSON**.

Обходит файлы, применяет регулярные выражения с указанием у**ровней опасности**, **рекомендаций** по избавлениям

nuclearss-pdf

генератор отчета

Принимает JSON-данные от **nuclearss-seeker** и создает **отчет** для группы безопасности.

nuclearss

оркестратор и **TUI.**

Запускает **nuclearss-seeker** и, если обнаружены вредоносные программы, открывает **терминальный интерфейс**.

Позволяет добавить определенный секрет или файл в с**писок исключений** — сохраняется в **.nuclearss**.

```
kairos@kairos:~/Desktop/repo/NuclearSecretSeaker-Test$
```

Отчет о найденных секретах

Secret Leak Report

Generated: 2026-03-08 01:05:26

Summary

Total findings: 5

Average risk level: 55.7% (MEDIUM)

Findings

HIGH AWS Access Key ID in /home/kairos/Desktop/repo/NuclearSecretSeaker-Test/true/scripts/deploy.py on line 3

```
AWS_ACCESS_KEY_ID = "AKIAFAKE1234
```

Pair with Secret Access Key stored in secrets manager. Prefer IAM roles over access keys where possible.

Secret: `AKIAFAKE1234567890AB`

MEDIUM API Key in Variable in /home/kairos/Desktop/repo/NuclearSecretSeaker-Test/true/front/src/apiClient.js on line 3

```
const GOOGLE_MAPS_API_KEY = "AIzaSyD_fake_1234567890abcdefGhIjKlMn";
```

Secret: `API_KEY = "AIzaSyD_fake_1234567890abcdefGhIjKlMn`

MEDIUM API Key in Variable in /home/kairos/Desktop/repo/NuclearSecretSeaker-Test/true/front/src/apiClient.js on line 10

```
"X-Internal-Api-Key": "internal-api-key-9f8e7d6c5b4a3"
```

Secret: `Api-Key": "internal-api-key-9f8e7d6c5b4a3`

MEDIUM Generic Secret in /home/kairos/Desktop/repo/NuclearSecretSeaker-

Test/true/scripts/deploy.py on line 4

```
AWS_SECRET_ACCESS_KEY = "WJv6fFakeSecretAccessKeyExamplexYz123456"
```

Secret: `SECRET_ACCESS_KEY = "WJv6fFakeSecretAccessKeyExamplexYz123456"`

LOW mail in /home/kairos/Desktop/repo/NuclearSecretSeaker-Test/true/front/src/apiClient.js on line 4

```
const SENTRY_DSN =
"https://34e7f2c2f6a647caa1f0b3b8321c0f19@o123456.ingest.sentry.io/654321";
```

Secret: `34e7f2c2f6a647caa1f0b3b8321c0f19@o123456.ingest.sentry.io`

Ignored Items

Ignored Directories

`/home/kairos/Desktop/repo/NuclearSecretSeaker-Test/.idea`

Ignored Files

`/home/kairos/Desktop/repo/NuclearSecretSeaker-Test/.nuclearss`

`/home/kairos/Desktop/repo/NuclearSecretSeaker-Test/true/.env`

`/home/kairos/Desktop/repo/NuclearSecretSeaker-Test/true/webhooks.yaml`

Ignored Text Patterns

`eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJzdWIiOiI0MiIsImV4cCI6MTc2MjQwMDA wMH0.fakeJwtSignaturePart`

`redis://default:q9w8e7r6t5y4u3i2o1p@redis.internal.local:6379/0`

`ghp_fakeGitHubToken1234567890ABCDEFGhijk` `glpat-FAKEgitlabPersonalAc`

Generated automatically. Review findings and take appropriate action.

Будущее развитие

IDE плагины

Интеграция с IDE (VS Code, IntelliJ) для обнаружения секретов прямо во время написания кода.

Entropy-based detection

Использование анализа энтропии для обнаружения строк- закодированных секретов.

GitHub / GitLab integration

Автоматическое сканирование репозиториев и pull request.

ML-детектор секретов

Использование машинного обучения для выявления секретов.

Итог

NuclearSS решает ключевую проблему **DevSecOps**:

предотвращает утечку секретов до того, как она произойдёт

github.com/Fragoler/NuclearSecretSeaker

Основные преимущества

- минимально трудозатратная установка.
- прозрачность для разработчиков
- масштабируемая и настраиваемая архитектура
- интеграция в существующий workflow

Контакты tg:
@Fragoler2
@chronos221
@Vezzxc